Please support the OWASP mission to improve software security through open source initiatives and community education. Donate Now!

OWASP Code Review Guide

Main

owasp lab (cc) BY-SA

The current (July 2017) PDF version can be found here.

OWASP Code Review Guide is a technical book written for those responsible for code reviews (management, developers, security professionals). The primary focus of this book has been divided into two main sections. Section one is the “why and how of code reviews” and section two focuses on the “types of vulnerabilities and how to identify throughout the review”. While security scanners are improving every day the need for manual security code reviews still needs to have a prominent place in organizations’ SDLC (Secure Development Life Cycle) that desires good secure code in production.

Chapters in the second section are mostly based on the popular OWASP 2013 top 10. Here you will find most of the code examples for both on “what not to do” and on “what to do”. A word of caution on code examples; Perl is famous for its saying that there are 10,000 ways to do one thing. The same is true for C#, PHP, and Java or any other computer language. Now add in “Object-Oriented Programming” and if we are using design patterns or even what designs patterns are being used and sample code becomes very “iffy” in what to write. We tried to keep the sample code so code reviewers can see red flags and not “do it my way or else”.

The last section is the appendix. Here we have content like code reviewer check list, etc. of items that really don’t flow in book

This website uses cookies to analyze our traffic and only share that information with our analytics partners.

Accept

x

The OWASP® Foundation works to improve the security of software through its community-led open source software projects, hundreds of chapters worldwide, tens of thousands of members, and by hosting local and global conferences.

Project Information

- Lab Project
- Documentation
- Defender
- Builder

Downloads

Current PDF Version (July 2017) - 2.0

GitHub

GitHub Repo

Leaders

ford

Michaela Greiler

Licensing

OWASP Code Review Guide is free to use. It is licensed under the Creative Commons Attribution-ShareAlike 4.0 license, so you can copy, distribute and transmit the work, and you can adapt it, and use it commercially, but all provided that you attribute the work and if you alter, transform, or build upon this work, you may distribute the resulting work only under the same or similar license to this one.

Upcoming OWASP Global Events

OWASP Global AppSec EU 2026 - Vienna, Austria

- June 22-26, 2026

OWASP Global AppSec USA 2026 - San Francisco, CA

- November 2-6, 2026

OWASP Global AppSec EU 2027 - Vienna, Austria

- June 21-25, 2027

OWASP Global AppSec USA 2027 - Atlanta, GA

- September 20-24, 2027

OWASP Global AppSec EU 2028 - Vienna, Austria

- June 19-23, 2028

Edit on GitHub

Spotlight: Automattic

AUTOMATTIC
This website uses cookies to analyze our traffic and only share that information with our analytics partners.
Accept
x

We are the people behind WordPress.com, Woo, Jetpack, WordPress VIP, Simplenote, Longreads, The Atavist, WPScan, Akismet, Gravatar, Crowdsignal, Cloudup, Tumblr, Day One, Pocket Casts, Newspack, Beeper, and more. We're a distributed company with 1,914 Automatticians in 93 countries speaking 117 different languages. We're committed to diversity, equity, and inclusion, and our common goal is to democratize publishing and commerce so that anyone with a story can tell it, and anyone with a product can sell it, regardless of income, gender, politics, language, or where they live in the world.

Corporate Supporters

SecureFlag SQ1 GitGuardian OSec

equixly Invicti PROMON NowSecure

FUJITSU

Become a corporate supporter

OWASP, the OWASP logo, and Global AppSec are registered trademarks and AppSec Days, AppSec California, AppSec Cali, SnowFROC, and LASCON are trademarks of the OWASP Foundation, Inc. Unless otherwise specified, all content on the site is Creative Commons Attribution-ShareAlike v4.0 and provided without warranty of service or accuracy. For more information, please refer to our General Disclaimer. OWASP does not endorse or recommend commercial products or services, allowing our community to remain vendor neutral with the collective wisdom of the best minds in software security worldwide. Copyright 2024, OWASP Foundation, Inc.

This website uses cookies to analyze our traffic and only share that information with our analytics partners.

Accept

x